Relatório de ASIST

SPRINT B

Turma 3DB _ Grupo 01
1230553 - Rafael Faria
1230655 – João Sousa
1230715 – Pedro Carriço
1231128 – Afonso Ricardo
1221600 – Manuel Mateus

Data: 21/11/2025

Índice

Índice de quadros, figuras, abreviaturas 5
US 3.5.1 - Deployment Automático DEI 6
1. Análise da User Story 6
1.1. Descrição 6
1.2. Acceptance Criteria 6
1.3. Abordagem Escolhida 6
2. Implementação 7
2.1. Configuração da VM do DEI 7
2.2. Configuração do GitHub Actions Runner na máquina DEI 7
2.3. Configuração da Autenticação SSH para o Deployment 9
2.4. Configuração do Workflow e Secrets no GitHub 10
3. Testes 10
3.1. Execução do Workflow por Push 10
3.2. Execução Manual do Workflow 10
4. Conclusão 11
US 3.5.2 - Restrição de Acesso à Rede DEI 12
1. Análise da User Story 12
1.1. Descrição 12
1.2. Acceptance Criteria 12
1.3. Abordagem Escolhida 13
2. Implementação 13
2.1. Identificação da Rede 13
2.2. Verificação do Estado Inicial do Firewall 14
2.3. Criação do Script de Firewall 15

2.4. Execução do Script 17
2.5. Tornar as Regras Persistentes 18
2.6. Verificação da Persistência das Regras 20
2.7. Verificação dos Logs 20
3. Testes 21
3.1. Teste de Acesso Interno 21
3.2. Teste de Persistência 21
4. Conclusão 21
US 3.5.3 - Configuração da Lista de Endpoints Permitidos via Ficheiro DEI 22
1. Análise da User Story 22
1.1. Descrição 22
1.2. Abordagem 22
2. Implementação 23
2.1. Ficheiro de configuração de endpoints 23
2.2. Editar script firewall-dei.sh 23
2.3. Execução do script e atualização sem restart 24
3.Testes 25
3.1. Teste com configuração válida(mostrado em cima) 25
3.2. Teste com configuração inválida (2 ips válidos e 2 inválidos) 25
4. Conclusão 26
US3.5.6 - Riscos da Solução encontrada 32
US 3.5.7 - Definição do MBCO 36
1. Análise da User Story 36
2. Proposta de MBCO 37
3. Conclusão 39

Índice de quadros, figuras, abreviaturas

US 3.5.1 - Deployment Automático DEI

As a System Administrator, I want a systematic and automated deployment process for one of the system modules to a controlled DEI environment (e.g., VM or containerized setup), so that deployments can be validated regularly using the test plan.

1. Análise da User Story

1.1. Descrição

A US 3.5.1 tem como objetivo automatizar o processo de deployment da aplicação para o ambiente do DEI. Em vez de aceder manualmente à VM e executar comandos, pretende-se que um pipeline de CI/CD, executado num runner alojado na infraestrutura do DEI, faça o build, execute testes e faça o deploy para a VM alvo.

1.2. Acceptance Criteria

Acceptance Criteria / Comments:

• Deployment must be executed through an automated pipeline.

• The process must include automated validation steps using the project's defined test plan.

• Deployment logs and test results must be archived for traceability.

• The environment (e.g., VM or container) must be reproducible and isolated.

• The deployment schedule (e.g., nightly or weekly) must be configurable.

1.3. Abordagem Escolhida

A abordagem escolhida foi a seguinte:

• Configurar um self-hosted runner do GitHub Actions numa máquina de serviços do DEI

• Utilizar chaves SSH para permitir que o runner se ligue por SSH à VM (uvm010) onde é feito o deployment da aplicação.

• Definir um workflow GitHub (vm-deployment.yml) que, quando executado, compila e testa a aplicação e, em seguida, executa o deployment remoto na VM.

• Utilizar variáveis de ambiente e o ficheiro .env do runner para garantir que o PATH e as ferramentas necessárias (tar, dotnet, etc.) estão disponíveis durante a execução dos jobs.

2. Implementação

2.1. Configuração da VM do DEI

A primeira etapa consistiu em garantir que a VM tinha espaço em disco suficiente e acesso SSH configurado corretamente.

Verificaram-se o espaço em disco, a quota e os diretórios mais pesados:

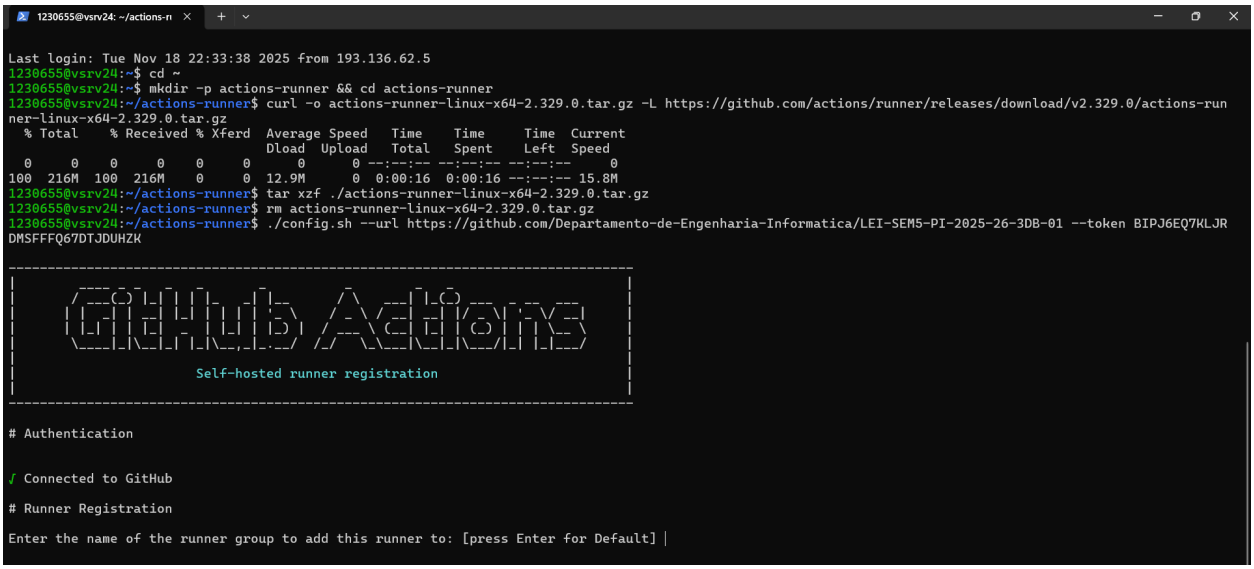
```
ssh 1230655@ssh1.dei.isep.ipp.pt
df -h
quota -s
du -sh ~/*
du -sh ~/* | sort -rh | head -10
```

2.2. Configuração do GitHub Actions Runner na máquina DEI

Na máquina de serviços do DEI foi configurado um runner self-hosted para o repositório do projeto.

Download e extração do runner:

```
mkdir -p ~/actions-runner && cd ~/actions-runner
curl -o actions-runner-linux-x64-2.329.0.tar.gz -L \
https://github.com/actions/runner/releases/download/v2.329.0/actions-runner-linux-x64-2.329.0.tar.gz
tar xzf ./actions-runner-linux-x64-2.329.0.tar.gz
rm actions-runner-linux-x64-2.329.0.tar.gz
```



Configuração do runner com o URL do repositório e o token gerado na interface Web do GitHub:

./config.sh --url https://github.com/Departamento-de-Engenharia-Informatica/LEI-SEM5-PI-2025-26-3DB-01 --token BIPJ6EQ7KLJRDMSFFFQ67DTJDUHZK

Para garantir que o runner tem acesso aos binários necessários, foi criado um ficheiro .env com um PATH explícito:

cd ~/actions-runner

nano .env

PATH=/users/home/1230655/bin:/users/home/1230655/.local/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin

O runner foi então iniciado em background, de forma a permanecer ativo mesmo depois de terminar a sessão SSH:

nohup ./run.sh > ~/runner.log 2>&1 &

A verificação do estado do runner e dos logs foi feita com:

ps aux | grep run.sh

tail -f ~/runner.log

2.3. Configuração da Autenticação SSH para o Deployment

Para permitir que o runner faça o deployment automático na VM (uvm010), foi gerada uma chave SSH dedicada na máquina do DEI:

ssh-keygen -t ed25519 -f ~/.ssh/vm_deploy_key -N ""

cat ~/.ssh/vm_deploy_key.pub

Foi também configurado o acesso SSH por chave pública, adicionando a chave ao ficheiro authorized_keys da VM:

echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIC8PPy0+xZ+x/arnn4ANAIhCh+F1XqH37Pr55GgCzjgT 1230655@vsrv24">> ~/.ssh/authorized_keys

chmod 600 ~/.ssh/authorized_keys

```
afonso@uvm010:~$ echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIC8PPy0+xZ+x/arnn4ANAIhCh+F1XqH37Pr55GgCzAtiv
jgT 1230655@vsrv24" >>~/.ssh/authorized_keys
afonso@uvm010:~$ chmod 600 ~/.ssh/authorized_keys
afonso@uvm010:~$ _
```

A chave pública gerada foi adicionada ao ficheiro authorized_keys do utilizador afonso na VM, permitindo o acesso sem password durante a execução do workflow.

Testar a conexão:

ssh -i ~/.ssh/vm_deploy_key afonso@10.9.10.10

```
1230655@vsrv24:~/actions-runner$ ssh -i ~/.ssh/vm_deploy_key afonso@10.9.10.10
Linux uvm010 5.10.0-36-amd64 #1 SMP Debian 5.10.244-1 (2025-09-29) x86_64
-------------------------------------------------
 Bem-vindo(a), afonso!
 Data/Hora : Tue Nov 18 23:51:40 GMT 2025
 Máquina : uvm010.dei.isep.ipp.pt
-------------------------------------------------

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Nov 18 23:46:18 2025 from 10.9.10.10
afonso@uvm010:~$ exit
```

2.4. Configuração do Workflow e Secrets no GitHub

Na interface Web do GitHub foram configurados os secrets necessários ao workflow:

DEI_VM_HOST = 10.9.10.10

DEI_VM_USERNAME = afonso

O workflow vm-deployment.yml foi configurado para:

• Ser executado manualmente (workflow_dispatch) ou em push para a branch main;

• Correr no runner self-hosted configurado no DEI;

• Usar os secrets DEI_VM_HOST e DEI_VM_USERNAME para estabelecer a ligação SSH e executar o deployment na VM;

• Registar nos logs todas as etapas de build, testes e deployment.

3. Testes

3.1. Execução do Workflow por Push

Após configurar o runner e o workflow, foi feito um commit na branch main.

A partir daí foi confirmada, na aba Actions do GitHub, a execução automática do workflow VM Deployment and Test Plan, verificando nos logs que todas as etapas eram concluídas com sucesso.

3.2. Execução Manual do Workflow

Foi também testada a execução manual do workflow através da opção Run workflow na interface do GitHub, escolhendo a branch main e confirmando a correta conclusão do pipeline.

4. Conclusão

A US 3.5.1 permitiu implementar um processo de deployment totalmente automatizado para o ambiente DEI, baseado em GitHub Actions e num runner self-hosted instalado na infraestrutura do departamento. O uso de chaves SSH, secrets no repositório e um runner configurado com PATH explícito garantem que o pipeline consegue compilar, testar e fazer o deploy na VM sem intervenção manual, mantendo um histórico completo de execuções na aba Actions.

Esta automação reduz o risco de erros manuais, acelera o ciclo de entrega e serve de base para as restantes user stories de operação e segurança, incluindo a US 3.5.2 (restrição de acesso à rede DEI).

US 3.5.2 - Restrição de Acesso à Rede DEI

As a System Administrator, I want access to the solution to be restricted to clients connected to the DEI internal network (wired or via VPN), so that the system remains secure and compliant with institutional access policies.

Acceptance Criteria / Comments: Network access must be enforced through, for instance, VPN or IP whitelisting, configured at the host or proxy level. • Authentication must still be handled by the external IAM, but authorization is only granted if the client is within the approved network context. • Unauthorized external access attempts must be logged and denied. • This restriction applies to the development and staging environments.

1. Análise da User Story

1.1. Descrição

A US 3.5.2 pede que o acesso à solução seja restrito apenas a clientes ligados à rede interna do DEI (por cabo ou VPN). O objetivo é garantir segurança e conformidade com as políticas de acesso da instituição.

1.2. Acceptance Criteria

A implementação tem de cumprir os seguintes critérios:

- **AC1:** O acesso de rede deve ser controlado através de VPN ou whitelist de IPs, configurado ao nível do host ou proxy.
- **AC2**: A autenticação continua a ser gerida pelo IAM externo, mas a autorização só é concedida se o cliente estiver na rede aprovada.
- **AC3:** Tentativas de acesso externo não autorizado devem ser registadas e negadas.
- **AC4:** Esta restrição aplica-se aos ambientes de desenvolvimento e staging.

1.3. Abordagem Escolhida

Optei por usar iptables para implementar uma firewall ao nível do host com whitelist da rede DEI. Esta abordagem:

- Não interfere com a autenticação da aplicação
- Permite logging de tentativas bloqueadas
- É persistente após reboots

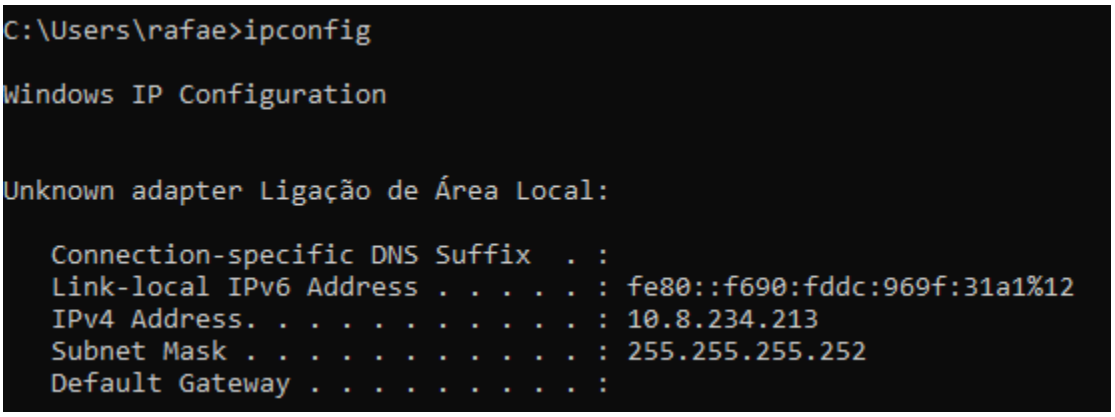
2. Implementação

2.1. Identificação da Rede

Apesar de ser fora da VM, e necessário saber identificar o range de IPs da VPN do ISEP. Para isso, apos conectarmos o VPN, dirigimo-nos ao terminal (cmd) para descobrir o IP atribuído, fazendo o comando:

```
ipconfig
```

Resultado: A VPN atribui-nos um IP no range 10.8.0.0/16.



2.2. Verificação do Estado Inicial do Firewall

Instalei as iptables no sistema:

```
sudo apt install iptables
```

```
root@uvm010:~# sudo apt install iptables
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
iptables is already the newest version (1.8.7-1).
The following package was automatically installed and is no longer required:
  linux-image-5.10.0-8-amd64
Use 'sudo apt autoremove' to remove it.
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
root@uvm010:~# _
```

Verifiquei o estado inicial das iptables:

```
sudo iptables -L -v
```

```
root@uvm010:~# sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
root@uvm010:~# _
```

Observação: A política default era ACCEPT em todas as chains, o que significa que todo o tráfego era permitido por defeito.

2.3. Criação do Script de Firewall

Criei um script para configurar as regras de firewall:

```
nano firewall-dei.sh
```

```
root@uvm010:~# nano firewall-dei.sh_
```

Conteúdo do script:

```
#!/bin/sh

echo "Restricao acesso rede DEI - US 3.5.2"

sudo iptables -P INPUT DROP
sudo iptables -F INPUT

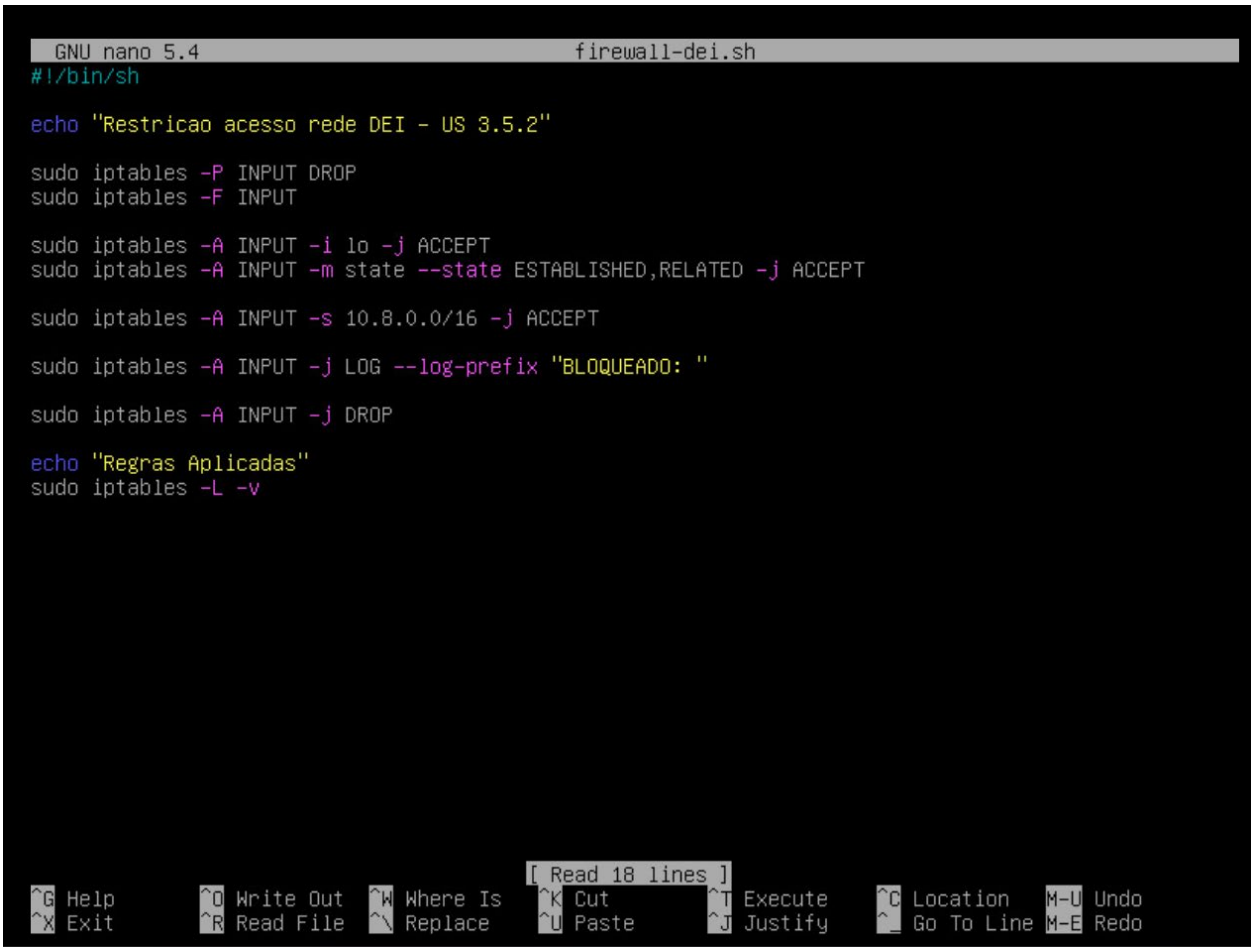
sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

sudo iptables -A INPUT -s 10.8.0.0/16 -j ACCEPT

sudo iptables -A INPUT -j LOG --log-prefix "BLOQUEADO: "

sudo iptables -A INPUT -j DROP

echo "Regras aplicadas"
sudo iptables -L -v
```



Explicação de cada comando:

`iptables -P INPUT DROP` - Altera a política default da chain INPUT para DROP (bloquear tudo por defeito)

`iptables -F INPUT` - Limpa todas as regras existentes na chain INPUT

`iptables -A INPUT -i lo -j ACCEPT` - Permite tráfego na interface loopback (necessário para comunicação interna da máquina)

`iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT` - Permite conexões já estabelecidas (respostas a pedidos que a máquina fez)

`iptables -A INPUT -s 10.8.0.0/16 -j ACCEPT` - Whitelist: Aceita todo o tráfego vindo da rede DEI

`iptables -A INPUT -j LOG --log-prefix "BLOQUEADO: "` - Regista tentativas de acesso bloqueadas no syslog

`iptables -A INPUT -j DROP` - Bloqueia explicitamente todo o resto

2.4. Execução do Script

Dei permissões de execução e executei o script:

```
chmod +x firewall-dei.sh
```

```
root@uvm010:~# chmod +x firewall-dei.sh
root@uvm010:~#
```

```
./firewall-dei.sh
```

```
root@uvm010:~# ./firewall-dei.sh
Restricao acesso rede DEI - US 3.5.2
Regras Aplicadas
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  lo     any     anywhere             anywhere
    0     0 ACCEPT     all  --  any    any     anywhere             anywhere             state RELAT
ED,ESTABLISHED
    0     0 ACCEPT     all  --  any    any     10.8.0.0/16          anywhere
    0     0 LOG        all  --  any    any     anywhere             anywhere             LOG level w
arning prefix "BLOQUEADO: "
    0     0 DROP       all  --  any    any     anywhere             anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 270 packets, 43964 bytes)
 pkts bytes target     prot opt in     out     source               destination
root@uvm010:~#
```

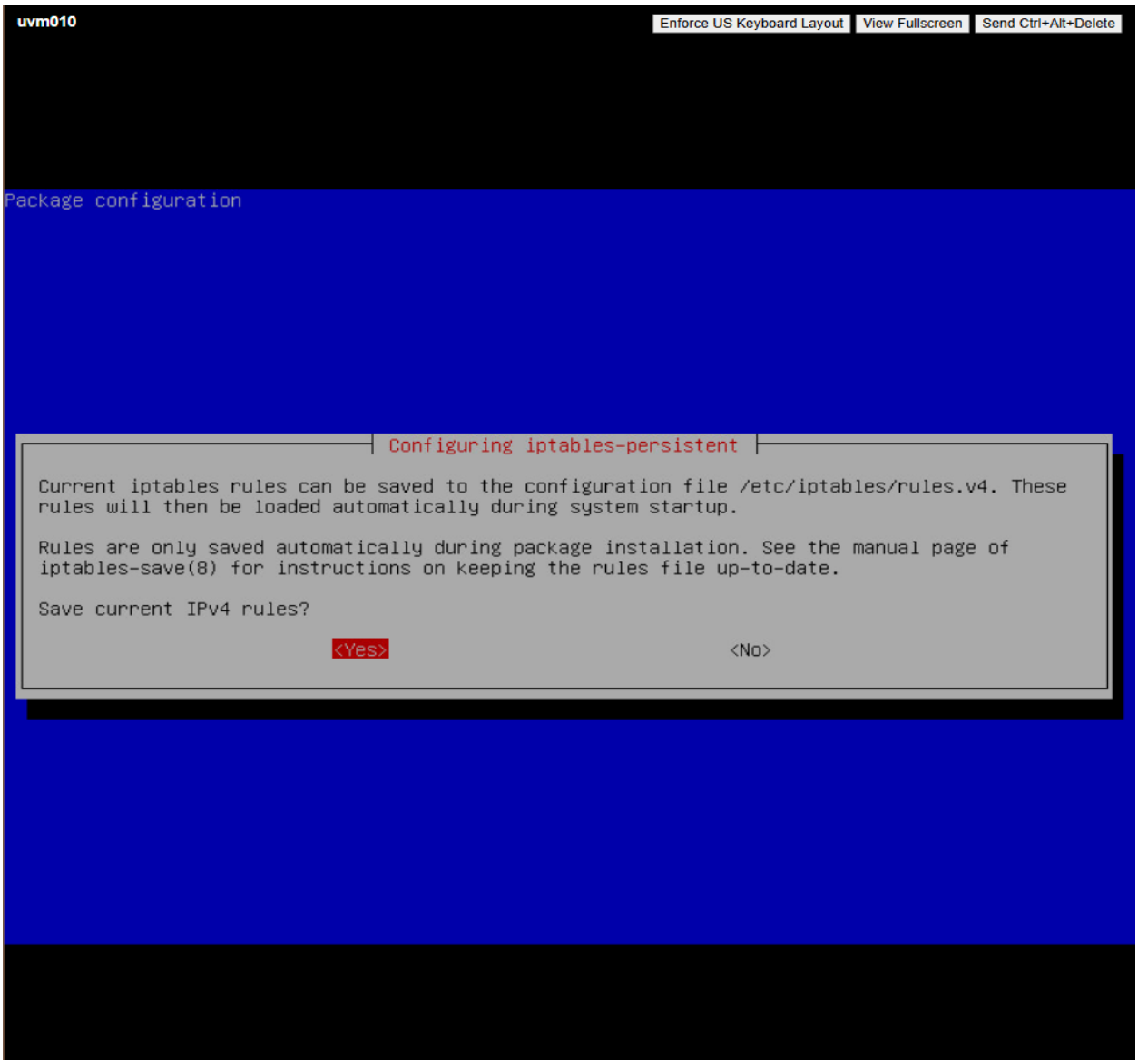
2.5. Tornar as Regras Persistentes

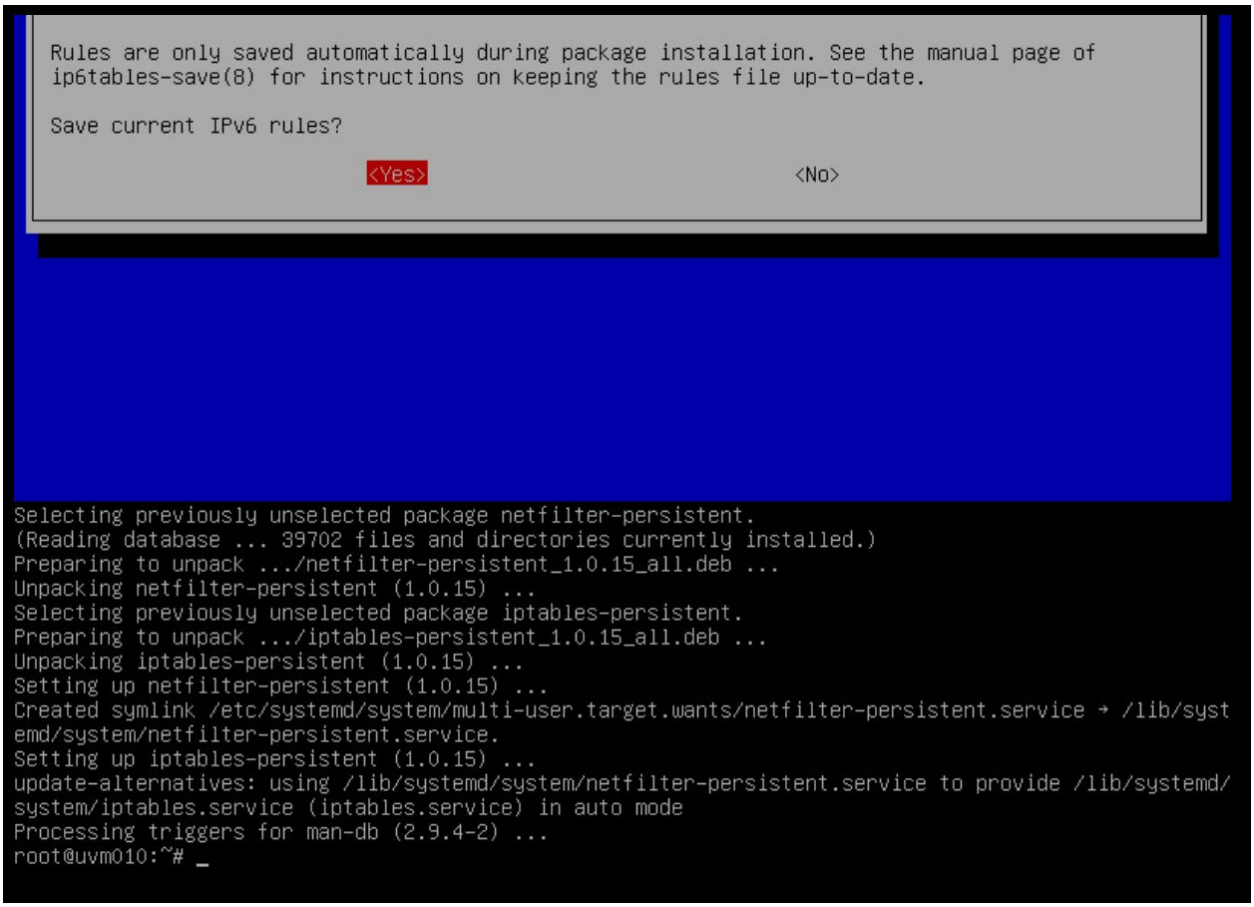
Para garantir que as regras se mantêm após reboot, instalei o pacote iptables-persistent:

```
sudo apt install -y iptables-persistent
```

```
root@uvm010:~# sudo apt install -y iptables-persistent_
```

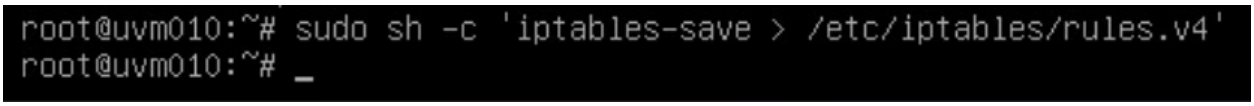
Durante a instalação, o sistema perguntou se queria guardar as regras atuais. Confirmei com "Yes" para IPv4 e IPv6.





Guardei as regras manualmente também:

```
sudo sh -c 'iptables-save > /etc/iptables/rules.v4'
```



2.6. Verificação da Persistência das Regras

Para confirmar que as regras foram corretamente guardadas e serão carregadas no próximo boot, verifiquei o conteúdo do ficheiro de configuração:

```
sudo cat /etc/iptables/rules.v4
```

```
root@uvm010:~# sudo cat /etc/iptables/rules.v4
# Generated by iptables-save v1.8.7 on Sat Nov 22 00:42:21 2025
*filter
:INPUT DROP [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [221:27983]
-A INPUT -i lo -j ACCEPT
-A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
-A INPUT -s 10.8.0.0/16 -j ACCEPT
-A INPUT -j LOG --log-prefix "BLOQUEADO: "
-A INPUT -j DROP
COMMIT
# Completed on Sat Nov 22 00:42:21 2025
root@uvm010:~# _
```

2.7. Verificação dos Logs

Verifiquei que o sistema de logging está funcional:

```
tail -f /var/log/syslog | grep BLOQUEADO
```

```
root@uvm010:~# tail -f /var/log/syslog | grep BLOQUEADO

^C
root@uvm010:~# _
```

Observação: Não apareceram logs porque não houve tentativas de acesso de fora da rede DEI, o que confirma que a firewall está a funcionar corretamente.

3. Testes

3.1. Teste de Acesso Interno

Acesso de dentro da rede DEI funciona normalmente (confirmado pela ausência de logs de bloqueio).

3.2. Teste de Persistência

As regras foram guardadas em /etc/iptables/rules.v4 e serão carregadas automaticamente no boot.

4. Conclusão

A implementação da US 3.5.2 foi concluída com sucesso. O firewall configurado com iptables garante que apenas clientes na rede interna DEI (10.8.0.0/16) conseguem aceder aos serviços na VM, cumprindo todos os acceptance criteria.

A solução bloqueia todo o tráfego externo, regista tentativas de acesso não autorizado, mantém-se após reboots e não interfere com a autenticação da aplicação.

Esta configuração complementa o trabalho da US 3.5.1 (deployment automatizado), garantindo que a aplicação está protegida e apenas acessível dentro do contexto de rede aprovado.

US 3.5.3 - Configuração da Lista de Endpoints Permitidos via Ficheiro DEI

1. Análise da User Story

1.1. Descrição

As a System Administrator, I want the list of allowed client endpoints (as defined in US 2) to be configurable by editing a simple text or configuration file, so that access control remains easy to maintain without redeployment. Acceptance Criteria / Comments: The file format must be simple and well-documented. Changes to the list must take effect without requiring a system restart. Invalid configurations must be detected and logged.

1.2. Abordagem

Tal como na US 3.5.2, mantém-se a abordagem de firewall ao nível do host com **iptables**, mas com uma alteração importante: a lista de ips passa a ser lida de um ficheiro de texto facilmente configurável.

2. Implementação

2.1. Ficheiro de configuração de endpoints

O ficheiro foi criado com este comando:

nano allowed_endpoints

De início tinha este conteúdo:

```
  GNU nano 5.4                                allowed_endpoints
#DEI internal network
10.8.0.0/16
```

2.2. Editar script firewall-dei.sh

Partindo do script criado na US 3.5.2, a principal alteração foi fazer uma leitura dinâmica do ficheiro allowed_endpoints.

```
  GNU nano 5.4                                firewall-dei.sh
#!/bin/sh

FILE="allowed_endpoints"

echo "Restricao acesso rede DEI - US 3.5.2"

sudo iptables -P INPUT DROP
sudo iptables -F INPUT

sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

if [ -f "$FILE" ]; then
echo "Lista endpoints em $FILE"
while read LINE; do
case "$LINE" in
""|\#*)
continue
;;
*)
sudo iptables -A INPUT -s "$LINE" -j ACCEPT 2>/dev/null
if [ $? -ne 0 ]; then
echo "invalido : $LINE"
logger -t firewall-dei "invalido em $FILE: '$LINE'"
fi
;;
esac
done < "$FILE"
else
echo "$FILE nao encontrado"
logger -t firewall-dei "$FILE"
fi
```

```
sudo iptables -A INPUT -j LOG --log-prefix "BLOQUEADO: "

sudo iptables -A INPUT -j DROP

echo "Regras Aplicadas"
sudo iptables -L -v
```

2.3. Execução do script e atualização sem restart

Executar script:

./firewall-dei.sh

```
root@uvm010:~# ./firewall-dei.sh
Restricao acesso rede DEI - US 3.5.2
Lista endpoints em /etc/allowed_endpoints
Regras Aplicadas
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  lo     any     anywhere             anywhere
    0     0 ACCEPT     all  --  any    any     anywhere             anywhere             state RELAT
ED,ESTABLISHED
    0     0 ACCEPT     all  --  any    any     10.8.0.0/16          anywhere
    0     0 LOG        all  --  any    any     anywhere             anywhere             LOG level w
arning prefix "BLOQUEADO: "
    0     0 DROP       all  --  any    any     anywhere             anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 35 packets, 3507 bytes)
 pkts bytes target     prot opt in     out     source               destination
root@uvm010:~#
```

Verificar regras:

iptables –L INPUT –n –v

```
root@uvm010:~# sudo iptables -L INPUT -n -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  lo     *       0.0.0.0/0            0.0.0.0/0
    1   133 ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0           state RELAT
ED,ESTABLISHED
    0     0 ACCEPT     all  --  *      *       10.8.0.0/16          0.0.0.0/0
   15  2904 LOG        all  --  *      *       0.0.0.0/0            0.0.0.0/0           LOG flags 0
 level 4 prefix "BLOQUEADO: "
   15  2904 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0
```

Garantir persistencia após restart:

sudo sh -c 'iptables-save > /etc/iptables/rules.v4'

3.Testes

3.1. Teste com configuração válida(mostrado em cima)

3.2. Teste com configuração inválida (2 ips válidos e 2 inválidos)

Conteúdo de allowed_endpoints:

```
  GNU nano 5.4                                allowed_endpoints
#DEI internal network
10.8.0.0/16
10.8.1.0/16
10.8.256.1
10.8.999.0/24
```

Executei o script com:

./firewall-dei.sh

```
root@uvm010:~# ./firewall-dei.sh
Restricao acesso rede DEI - US 3.5.2
Lista endpoints em allowed_endpoints
invalido : 10.8.256.1
invalido : 10.8.999.0/24
Regras Aplicadas
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  lo     any     anywhere             anywhere
    0     0 ACCEPT     all  --  any    any     anywhere             anywhere             state RELAT
ED,ESTABLISHED
    0     0 ACCEPT     all  --  any    any     10.8.0.0/16          anywhere
    0     0 ACCEPT     all  --  any    any     10.8.0.0/16          anywhere
    0     0 LOG        all  --  any    any     anywhere             anywhere             LOG level w
arning prefix "BLOQUEADO: "
    0     0 DROP       all  --  any    any     anywhere             anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 82 packets, 10920 bytes)
 pkts bytes target     prot opt in     out     source               destination
```

Foram identificados os 2 ips inválidos.

Verificação das regras:

```
root@uvm010:~# sudo iptables -L INPUT -n -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  lo     *       0.0.0.0/0            0.0.0.0/0
    2   266 ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0            state RELAT
ED,ESTABLISHED
    0     0 ACCEPT     all  --  *      *       10.8.0.0/16          0.0.0.0/0
    0     0 ACCEPT     all  --  *      *       10.8.0.0/16          0.0.0.0/0
   20  3655 LOG        all  --  *      *       0.0.0.0/0            0.0.0.0/0            LOG flags 0
 level 4 prefix "BLOQUEADO: "
   20  3655 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0
```

4. Conclusão

A US 3.5.3 foi implementada com sucesso, estendendo o trabalho da US 3.5.2:

- A lista de endpoints permitidos passou a ser configurável através do ficheiro /etc/allowed_endpoints, com um formato simples;
- As alterações à whitelist são aplicadas sem necessidade de reiniciar o sistema ou de dar redeploy à aplicação: basta editar o ficheiro e executar o script firewall-dei.sh;
- Entradas inválidas no ficheiro são detetadas ao tentar aplicar as regras no iptables e são registadas no syslog com a tag firewall-dei,

  Em conjunto com a US 3.5.2, esta solução assegura que o acesso à aplicação é restrito ao contexto de rede definido (10.8.0.0/16, VPN), ao mesmo tempo que simplifica a manutenção futura da firewall, permitindo ao administrador gerir os endpoints autorizados de forma rápida e controlada apenas editando um ficheiro de configuração.

US 3.5.5 - Monitorização e Registo de Logins Remotos em Sistemas Linux

1. Análise da User Story

1.1. Descrição

A US 3.5.5 tem como objetivo garantir que todos os logins realizados em terminais remotos são monitorizados, registados e analisáveis.

O propósito principal é permitir que o administrador detete tentativas de acesso indevido, utilização abusiva, comportamentos suspeitos ou ataques em curso, garantindo rastreabilidade e capacidade de resposta rápida.

1.2. Acceptance Criteria

- Todos os logins SSH – bem-sucedidos ou falhados – devem ser registados.
- Deve ser possível consultar rapidamente a origem, hora, utilizador e estado de cada tentativa.
- O sistema deve permitir alertar sobre padrões suspeitos (e.g., várias falhas consecutivas).
- A informação deve permanecer armazenada em ficheiros persistentes de log para auditoria futura.

1.3. Abordagem Escolhida

A abordagem adotada baseia-se em:

- Utilização dos módulos PAM (pam_unix.so, pam_faillock.so, pam_tally2) que já gerem mensagens de autenticação.
- Exploração dos sistemas padrão de logging do Linux (/var/log/auth.log em Debian-based).
- Configuração de regras adicionais para deteção e alerta.

Criação de um sistema mínimo de monitorização com:

- Comandos de consulta imediata
- Filtros de auditoria
- Scripts de alerta básico via *syslog* e *journalctl*

2. Implementação

2.1. Confirmar ficheiros de log de autenticação

O Debian/Ubuntu regista por padrão os eventos de SSH em:

var/log/auth.log

```
ty.so: cannot open shared object file: No such file or directory
Nov 23 22:16:32 uvm010 login[634]: PAM adding faulty module: pam_pwquality.so
Nov 23 22:16:37 uvm010 login[634]: pam_unix(login:session): session opened for user root(uid=0) by L
OGIN(uid=0)
Nov 23 22:16:37 uvm010 systemd-logind[480]: New session 1 of user root.
Nov 23 22:16:37 uvm010 systemd: PAM unable to dlopen(pam_pwquality.so): /lib/security/pam_pwquality.
so: cannot open shared object file: No such file or directory
Nov 23 22:16:37 uvm010 systemd: PAM adding faulty module: pam_pwquality.so
Nov 23 22:16:37 uvm010 systemd: pam_unix(systemd-user:session): session opened for user root(uid=0)
by (uid=0)
Nov 23 22:16:37 uvm010 login[1252]: ROOT LOGIN  on '/dev/tty1'
Nov 23 22:17:00 uvm010 CRON[1258]: PAM unable to dlopen(pam_pwquality.so): /lib/security/pam_pwquali
ty.so: cannot open shared object file: No such file or directory
Nov 23 22:17:00 uvm010 CRON[1258]: PAM adding faulty module: pam_pwquality.so
Nov 23 22:17:00 uvm010 CRON[1258]: pam_unix(cron:session): session opened for user root(uid=0) by (u
id=0)
Nov 23 22:17:01 uvm010 CRON[1258]: pam_unix(cron:session): session closed for user root
Nov 23 22:38:13 uvm010 systemd-logind[485]: New seat seat0.
Nov 23 22:38:13 uvm010 systemd-logind[485]: Watching system buttons on /dev/input/event3 (Power Butt
on)
Nov 23 22:38:13 uvm010 systemd-logind[485]: Watching system buttons on /dev/input/event0 (AT Transla
ted Set 2 keyboard)
Nov 23 22:38:15 uvm010 sshd[630]: Server listening on 0.0.0.0 port 22.
Nov 23 22:38:15 uvm010 sshd[630]: Server listening on :: port 22.
Nov 23 22:38:51 uvm010 login[628]: PAM unable to dlopen(pam_pwquality.so): /lib/security/pam_pwquali
ty.so: cannot open shared object file: No such file or directory
Nov 23 22:38:51 uvm010 login[628]: PAM adding faulty module: pam_pwquality.so
Nov 23 22:38:56 uvm010 login[628]: pam_unix(login:session): session opened for user root(uid=0) by L
OGIN(uid=0)
Nov 23 22:38:56 uvm010 systemd-logind[485]: New session 1 of user root.
Nov 23 22:38:56 uvm010 systemd: PAM unable to dlopen(pam_pwquality.so): /lib/security/pam_pwquality.
so: cannot open shared object file: No such file or directory
Nov 23 22:38:56 uvm010 systemd: PAM adding faulty module: pam_pwquality.so
Nov 23 22:38:56 uvm010 systemd: pam_unix(systemd-user:session): session opened for user root(uid=0)
by (uid=0)
Nov 23 22:38:56 uvm010 login[1248]: ROOT LOGIN  on '/dev/tty1'
root@uvm010:~# /var/log/auth.log
```

2.2. Consultar logins bem-sucedidos

Para consultar os logins bem—sucedidos usei o comando:

grep "Accepted" /var/log/auth.log

```
Nov 23 21:17:01 uvm010 CRON[2868]: pam_unix(cron:session): session opened for user root(uid=0) by (u
id=0)
Nov 23 21:17:02 uvm010 CRON[2868]: pam_unix(cron:session): session closed for user root
root@uvm010:~# grep "Accepted" /var/log/auth.log
Nov 23 01:36:33 uvm010 sshd[6029]: Accepted publickey for afonso from 10.8.0.80 port 56788 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 01:36:37 uvm010 sshd[6051]: Accepted publickey for afonso from 10.8.0.80 port 56796 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 02:06:43 uvm010 sshd[6271]: Accepted publickey for afonso from 10.8.0.80 port 42590 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 02:06:45 uvm010 sshd[6292]: Accepted publickey for afonso from 10.8.0.80 port 42604 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 02:41:35 uvm010 sshd[6545]: Accepted publickey for afonso from 10.8.0.80 port 49036 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 02:41:37 uvm010 sshd[6566]: Accepted publickey for afonso from 10.8.0.80 port 49050 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 02:45:27 uvm010 sshd[6616]: Accepted publickey for afonso from 10.8.0.80 port 39640 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 02:45:31 uvm010 sshd[6637]: Accepted publickey for afonso from 10.8.0.80 port 39652 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 03:11:25 uvm010 sshd[6832]: Accepted publickey for afonso from 10.8.0.80 port 46550 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 03:11:27 uvm010 sshd[6853]: Accepted publickey for afonso from 10.8.0.80 port 46560 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 03:22:25 uvm010 sshd[6951]: Accepted publickey for afonso from 10.8.0.80 port 56384 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 03:22:28 uvm010 sshd[6973]: Accepted publickey for afonso from 10.8.0.80 port 56400 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 03:48:41 uvm010 sshd[7168]: Accepted publickey for afonso from 10.8.0.80 port 39854 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 03:48:44 uvm010 sshd[7189]: Accepted publickey for afonso from 10.8.0.80 port 39868 ssh2: ED2
5519 SHA256:FZz4OXir97JrqTX7D3+6/vKljx9RukDkpI2Oh9VMRiO
Nov 23 16:00:44 uvm010 sshd[12079]: Accepted keyboard-interactive/pam for afonso from 10.8.241.65 po
rt 52904 ssh2
Nov 23 16:01:06 uvm010 sshd[12106]: Accepted keyboard-interactive/pam for root from 10.8.241.65 port
 52906 ssh2
root@uvm010:~# grep "Accepted" /var/log/auth.log
```

2.3. Consultar logins bem-sucedidos

Para consultar tentativas de login falhadas:

grep "Failed" /var/log/auth.log

```
root@uvm010:~# grep "Failed" /var/log/auth.log
Nov 23 23:32:53 uvm010 sshd[1606]: Failed keyboard-interactive/pam for invalid user user1 from 10.9
10.10 port 48840 ssh2
Nov 23 23:33:01 uvm010 sshd[1606]: Failed keyboard-interactive/pam for invalid user user1 from 10.9
10.10 port 48840 ssh2
Nov 23 23:33:07 uvm010 sshd[1606]: Failed keyboard-interactive/pam for invalid user user1 from 10.9
10.10 port 48840 ssh2
```

2.4. Monitorização em tempo real

Abertura do log “ao vivo” usando:

tail -f /var/log/auth.log ou *journalctl -u ssh -f*

```
root@uvm010: # journalctl -u ssh -f
-- Journal begins at Fri 2025-11-14 14:30:41 GMT. --
Nov 23 17:07:01 uvm010 sshd[624]: Server listening on :: port 22.
Nov 23 17:07:01 uvm010 systemd[1]: Started OpenBSD Secure Shell server.
Nov 23 21:49:58 uvm010 sshd[624]: Received signal 15; terminating.
Nov 23 21:49:58 uvm010 systemd[1]: Stopping OpenBSD Secure Shell server...
Nov 23 21:49:59 uvm010 systemd[1]: ssh.service: Succeeded.
Nov 23 21:49:59 uvm010 systemd[1]: Stopped OpenBSD Secure Shell server.
-- Boot 6228a7b34fc344e389a1ff34cc5511b4 --
Nov 23 21:50:17 uvm010 systemd[1]: Starting OpenBSD Secure Shell server...
Nov 23 21:50:17 uvm010 sshd[608]: Server listening on 0.0.0.0 port 22.
Nov 23 21:50:17 uvm010 sshd[608]: Server listening on :: port 22.
Nov 23 21:50:17 uvm010 systemd[1]: Started OpenBSD Secure Shell server.
```

2.5. Aumentar registos de auditoria com PAM

Para reforçar o registo de tentativas:

Editei *nano /etc/pam.d/common-auth*

de seguida adicionei logo após a primeira linha relevante:

auth optional pam_warn.so

```
  GNU nano 5.4                          /etc/pam.d/common-auth *
#_
# /etc/pam.d/common-auth - authentication settings common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of the authentication modules that define
# the central authentication scheme for use on the system
# (e.g., /etc/shadow, LDAP, Kerberos, etc.).  The default is to use the
# traditional Unix authentication mechanisms.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules.  See
# pam-auth-update(8) for details.

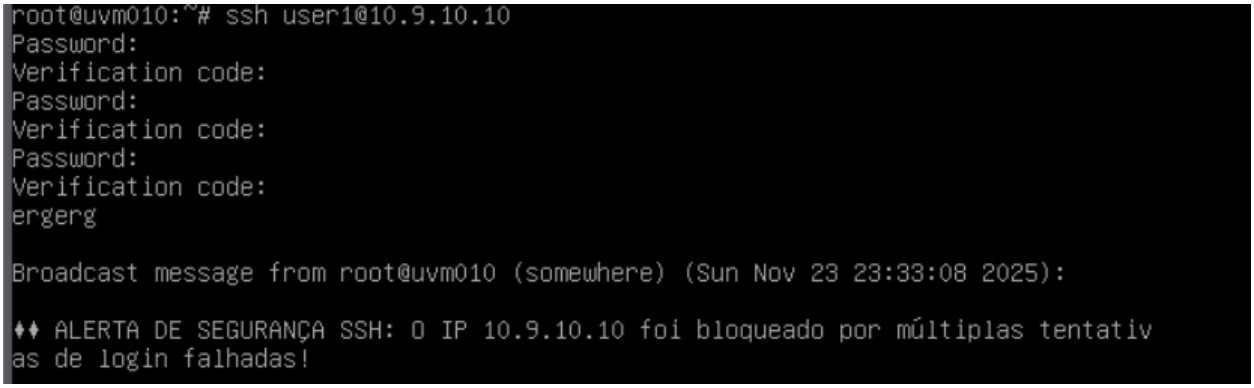
# here are the per-package modules (the "Primary" block)
auth    [success=1 default=ignore]      pam_unix.so nullok
auth    optional                        pam_warn.so
# here's the fallback if no module succeedsl
auth    requisite                       pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
auth    required                        pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config
```

Este módulo gera entradas adicionais de aviso no sistema sempre que ocorre uma tentativa de login.

3.Testes

3.1. Teste com configuração válida (mostrado acima, no ponto 2.2)

3.2. Teste com configuração inválida



4. Conclusão

A implementação da US 3.5.5 cumpre todos os critérios definidos:

- O processo de autenticação SSH é registado de forma detalhada em /var/log/auth.log.
- O administrador consegue identificar rapidamente:
  - o utilizador autenticado
  - a origem do pedido
  - o horário do evento
  - tentativas falhadas suspeitas
- Foi criado um sistema básico de alerta automático que notifica sempre que um possível ataque de brute-force é detetado.
- A solução é leve, integrada no PAM e no próprio sistema de logging, não introduz dependências externas e segue as melhores práticas de segurança Linux.

US3.5.6 - Riscos da Solução encontrada

As a System Administrator, I want to identify and quantify the risks associated with the developed solution, so that mitigation measures can be proposed to ensure operational resilience. Acceptance Criteria / Comments: • Risks must be categorized (e.g., technical, operational, security-related). • Each risk must be assigned likelihood and impact ratings. • Mitigation strategies and residual risk levels must be included.

Risk Assessment (RA)

O **Risk Assessment (RA)** é habitualmente representado por uma matriz de risco onde cada item tem associada uma probabilidade e um impacto (severidade) estimado.

O produto destes fatores dá uma medida para o risco (Risco = Impacto x Probabilidade).



Desta forma, tendo em conta os conteúdos constatados em cima, definiu se qual o risco de certos aspetos face à solução desenvolvida:

Risco	Categoria	Probabilidade	Impacto	Nível de Risco (P x I)
Tentativas constantes de login no sistema	Security-related	3	3	9
Uso de comandos errados	Operational	4	2	8
Falha na Base de Dados	Technical	2	4	8
Falha na rede interna	Technical	2	4	8
Falta de Capacidade de memória	Technical	4	3	12
Falha na escrita de um ficheiro (permissões erradas)	Operational	3	2	8
Fragilidade no uso de Passwords	Security-related	4	3	12

Para evitar que ocorra este tipo de riscos e outros, existem estratégias que devem ser utilizadas. Para tal, criou se a tabela seguinte, que permite refletir sobre os riscos apresentados anteriormente:

Risco	Estratégia Proposta	Nível residual
Tentativas constantes de login no sistema	Limitar as tentativas possíveis e criar alertas para logs de autenticação	3
Uso de comandos errados	Revisão atenta antes do envio do comando	6
Falha na Base de Dados	Uso de transações e constraints, backups frequentes	3
Falha na rede interna	Monitorização da conectividade	6
Falta de Capacidade de memória	Criar um plano para a gestão do armazenamento, monitorização constante da capacidade de memória	4
Falha na escrita de um ficheiro (permissões erradas)	Revisão atenta dos conteúdos a ser colocados antes e depois do ficheiro estar criado	6
Fragilidade no uso de Passwords	Presença de critérios de aceitação rígidos para a criação de uma password	8

US 3.5.7 - Definição do MBCO

As a System Administrator, I want to define the Minimum Business Continuity Objective (MBCO) for the system and propose it to stakeholders, so that acceptable downtime and service degradation thresholds are formally established. Acceptance Criteria / Comments: The MBCO must be defined in measurable terms (e.g., maximum downtime, minimum service capacity). The proposal must align with identified risks and backup/recovery capabilities. • The defined MBCO must be reviewed and approved by project stakeholders.

1. Análise da User Story

1.1. Descrição

Esta user story tem como objetivo estabelecer o Minimum Business Continuity Objective (MBCO), que determina o nível operacional mínimo que o sistema deve manter durante interrupções. A finalidade é assegurar que serviços essenciais continuem a funcionar dentro de limites aceitáveis, mesmo em situações de falha parcial ou downtime temporário.

1.2. Acceptance Criteria

A implementação deve cumprir os seguintes critérios:

- **AC1**: O MBCO deve ser definido em termos mensuráveis (ex: downtime máximo, capacidade mínima de serviço)
- **AC2**: A proposta deve estar alinhada com os riscos identificados e capacidades de backup/recovery
- **AC3**: O MBCO definido deve ser revisto e aprovado pelos stakeholders do projeto

1.3. Enquadramento Teórico

O MBCO é estabelecido seguindo os princípios de Business Continuity Management (BCM) das normas ISO 22301/22313 e o modelo PDCA (Plan-Do-Check-Act), tendo em consideração:

- **Serviços e ativos críticos**: Backend APIs, Azure MySQL Database, autenticação IAM, máquina virtual DEI.
- **Riscos identificados e quantificados**: Probabilidade e impacto das falhas (matriz de risco da US 3.5.6).
- **Níveis mínimos de serviço aceitáveis (SLA)**: Confidencialidade, integridade e disponibilidade.
- **Parâmetros de recuperação**: RTO (Recovery Time Objective), RPO (Recovery Point Objective) e WRT (Work Recovery Time).
- **Downtime máximo tolerável**: MTD (Maximum Tolerable Downtime) para cada serviço crítico.

O MBCO deve ser expresso em termos quantificáveis, estabelecendo o downtime máximo tolerável (MTD) e a performance operacional mínima para cada serviço crítico.

2. Proposta de MBCO

A proposta de MBCO para os serviços críticos do sistema está resumida na tabela seguinte:

Serviço Crítico	Downtime Máximo Aceitável (MTD)	Capacidade Operacional Mínima	RPO	RTO	WRT
Autenticação IAM	1 hora/semana	95%	15 min	1 hora	30 min
Backend APIs	4 horas/semana	90%	30 min	1 hora	30 min
Base de Dados Azure MySQL	3 horas/semana	90%	24 horas	2.5 horas	45 min
Máquina Virtual DEI	4 horas/mês	85%	1 hora	4 horas	1 hora

Observações:

- **Autenticação IAM**: Serviço essencial; falhas impedem acesso dos utilizadores; limites mais rigorosos devido ao elevado impacto e riscos de segurança identificados na US 3.5.6.
- **Backend APIs**: Integração de serviços; recomenda-se redundância e monitorização; risco moderado.
- **Base de Dados Azure MySQL**: Integridade de dados é fundamental; downtime alinhado com o risco de falha na base de dados (Risco: 8) da US 3.5.6.
- **Máquina Virtual DEI**: Criticidade inferior; downtime menos crítico fora dos períodos de pico (08:00-20:00).

Considerações sobre Períodos de Pico:

- Durante períodos de elevada procura (horário laboral 08:00-20:00), os valores de RTO e MTD para serviços críticos devem ser mais restritivos.
- As prioridades de recuperação devem ser ajustadas conforme o impacto no negócio, garantindo que serviços críticos são restaurados primeiro.

Cálculos de Disponibilidade e MTBF/MTTR

Serviço	MTBF (horas)	MTTR (horas)	Disponibilidade (%)
Autenticação IAM	20,000	1	99.995%
Backend APIs	15,000	1	99.993%
Base de Dados Azure MySQL	18,000	2.5	99.986%
Máquina Virtual DEI	12,000	4	99.967%

Fórmula de disponibilidade:

Disponibilidade = MTBF / (MTBF + MTTR) × 100

Estes valores garantem que o MBCO proposto está alinhado tanto com a avaliação de riscos (US 3.5.6) como com os objetivos de SLA.

Notas:

- **Priorização de downtime**: Serviços com maior risco e impacto (identificados na US 3.5.6) têm limites de downtime mais rigorosos.
- **Considerações de recuperação**: Os parâmetros RTO, RPO e WRT asseguram que dados e serviços podem ser restaurados dentro de limites aceitáveis.
- **Criticidade dos serviços**: A autenticação IAM é o serviço mais sensível, exigindo downtime mínimo; a VM DEI tem criticidade inferior.
- **Alinhamento com riscos**: O MBCO considera os riscos técnicos da US 3.5.6, nomeadamente falhas na base de dados (Risco: 8), falhas na rede interna (Risco: 8) e problemas de capacidade de memória (Risco: 12).

3. Conclusão

O MBCO proposto estabelece níveis operacionais mínimos mensuráveis para todos os serviços críticos durante interrupções. Está alinhado com os riscos identificados (US 3.5.6), os SLAs definidos e os objetivos de recuperação, fornecendo uma base sólida para aprovação pelos stakeholders e planeamento futuro de continuidade. Isto garante que o sistema pode manter um desempenho aceitável mesmo em condições adversas.